DPDP ACT 2023 COMPLIANCE AUDIT REPORT

HIGH SEVERITY - PRIORITY REMEDIATION REQUIRED

Target Application:

Vuln HR Portal

Example Org (test fixture)

Report Date	November 10, 2026
Testing Type	Source-code privacy and data-protection review (white-box), PII inventory, consent, rights, retention and safeguards
Target	vuln-hr-portal (deliberately vulnerable test app)
Risk Rating	HIGH
Total Findings	**3 Confirmed | 1 Requires Verification**
Classification	CONFIDENTIAL - Authorized Personnel Only
Prepared by	Vijaya Kumar L
Reviewed by	Example Reviewer

1. Executive Summary

This report presents the results of a review of how the source code collects, stores, uses, shares, retains and erases personal data, against the DPDP Act 2023 and the DPDP Rules 2025 of Vuln HR Portal. The assessment confirmed 3 gaps, with an overall risk rating of HIGH. The most serious is F-01: PAN and bank account numbers are stored and returned without encryption or masking. 1 further item depends on a setting the repository does not show and requires manual verification.

Every confirmed finding was traced from an entry point to the affected code with file and line evidence, checked by independent verifiers, and machine-validated against the source before inclusion. Recommendations describe the smallest safe fix; no code was changed during the audit.

1.1 Gap Summary

#	Finding	Severity	Obligation	CVSS	Status
F-01	PAN and bank account numbers are stored and returned without encryption or masking	HIGH	Reasonable security safeguards	-	Open
F-02	No erasure path exists for employee or payslip records	HIGH	Retention and erasure	-	Open
F-03	Full 12-digit Aadhaar number is stored for every employee	MEDIUM	Purpose limitation and minimisation	-	Open
V-01	No notice is visible where employee personal data is collected	UNVERIFIED	Notice	TBD	Needs Verification

1.2 Severity Distribution

CRITICAL	HIGH	MEDIUM	LOW / UNVERIFIED
0	2	1	1

2. Assessment Scope & Methodology

2.1 Scope

- Target: vuln-hr-portal (deliberately vulnerable test app) (source code, commit not recorded)
- In-scope paths: Whole repository
- Languages: JavaScript, SQL
- Frameworks and services detected: Express, Indian PII fields (Aadhaar/PAN/bank/salary/UAN), Stripe, Supabase, jsonwebtoken, node-postgres
- Profile: standard (3 independent verification vote(s) per candidate)

- Audit period: November 10, 2026

Timeline: the DPDP Rules 2025 were notified in November 2025. Most operational duties (Rules 3 and 5 to 16: notice, security safeguards, breach intimation, retention and erasure, children's data, rights and cross-border transfer) apply 18 months after notification, around May 2027; consent manager registration applies after one year.

2.2 Methodology

The review mapped how personal data enters, is stored, used, shared, retained and erased in the source code, and compared it with obligations under the Digital Personal Data Protection Act, 2023 and the DPDP Rules, 2025:

- Phase 0: scope and safety gate
- Phase 1: data map and PII inventory (machine-assisted)
- Phase 2: obligation-by-obligation review: notice, consent, purpose, minimisation, accuracy, security safeguards, breach readiness, retention and erasure, Data Principal rights, children's data, processors and cross-border transfer
- Phase 3: independent verification of every gap from source
- Phase 4: report with recommendations only

2.3 Tools

Tool	Version	Purpose	Status
semgrep	1.184.0	code patterns (SAST)	Ran
gitleaks	8.28.0	secrets in files and Git history	Ran
trivy	-	dependency CVEs, IaC/Dockerfile misconfiguration, secrets	Not installed
osv-scanner	osv-scanner version: 2.2.4	known vulnerabilities in lockfiles	Ran

3. Detailed Findings

Each gap below passed the evidence gate: the personal data involved, the obligation it breaks, a source trace with file and line, what is missing, and the concrete result. Personal data values are never shown; only fields, files and lines.

F-01 PAN and bank account numbers are stored and returned without encryption or masking [HIGH]

Location	db/schema.sql:3, src/routes/payslips.js:8-10
DPDP obligation	Reasonable security safeguards; Section 8(5); Rule 6(1)(a), Rule 6(1)(b); Data: PAN, Bank account

Example Org (test fixture)

In plain words	What this is: The payslips table keeps each employee's PAN and bank account number, and the payslip API returns them. Problem: They are stored as plain text and sent back in full; nothing is encrypted, masked or tokenised. If we skip it: Anyone who gets database, backup or API access sees complete financial identifiers, and the DPDP minimum safeguards are not met.
Description	The payslips table defines bank_account_no and pan as plain text columns, and the payslip route selects and returns both in full. No encryption, masking, obfuscation or tokenisation exists anywhere in the repository (grep for encrypt, cipher, kms, pgcrypto, mask returns no matches).
Business Impact	Financial identifiers of every employee are exposed in any database, backup or API leak. Missing Rule 6 minimum measures is a breach of Section 8(5), the provision carrying the highest penalty under the Act's Schedule.
Root Cause	No data-protection layer for sensitive columns; the API returns raw rows.

Evidence (source trace)	`1. db/schema.sql:3  (plain-text PAN and bank account)`
	`CREATE TABLE payslips (id SERIAL PRIMARY KEY, employee_id INT, month TEXT, net_pay NUMERIC, bank_account_no TEXT, ifsc TEXT, pan VARCHAR(10), pdf BYTEA);`
	`2. src/routes/payslips.js:8  (selected in full)`
	`const result = await db.query('SELECT pdf, net_pay, bank_account_no, pan FROM payslips WHERE employee_id = $1 AND month = $2', [employeeId, month]);`
	`3. src/routes/payslips.js:10  (returned in full)`
	`res.json(result.rows[0] || {});`

Recommendation	Encrypt pan and bank_account_no at rest (pgcrypto or application-level envelope encryption with a KMS key) and return masked values from the API. Files to change: db/schema.sql, src/routes/payslips.js

Fix example	`const row = result.rows[0];`
	`res.json({ ...row, pan: row && mask(row.pan), bank_account_no: row && mask(row.bank_account_no) });`
	`// mask = v => v ? '****' + v.slice(-4) : v`

Production risk of the fix	Medium. Needs a data migration to encrypt existing rows, and any report or export that reads these columns must decrypt through the new layer.
Regression test	Query the payslips table directly and assert pan is not plain text; call the API and assert only the last 4 characters are returned.
Classification	CWE-311, CWE-359 | A04:2025 | Confidence: High | Votes: 3 confirmed / 0 verify / 0 reject

F-02 No erasure path exists for employee or payslip records [HIGH]

Location	db/schema.sql:2-3 (no delete anywhere in src/)
DPDP obligation	Retention and erasure; Section 8(7), Section 12(3); Rule 8; Data: Employee profile, Payslip, PAN, Bank account, Aadhaar number

Example Org (test fixture)

In plain words	What this is: The app stores employee profiles and payslips. Problem: There is no code that ever deletes or anonymises them, and no retention period is defined, so data of employees who left is kept forever. If we skip it: Personal data is kept after its purpose ends, which the Act prohibits, and every old record stays exposed to future breaches.
Description	The employees and payslips tables have no retention fields, and the codebase contains no DELETE statement, ORM delete call, purge job or TTL for either table (grep for DELETE, delete(, destroy, purge, retention, ttl in src/ returns nothing).
Business Impact	Indefinite retention of employee identity and financial data after the purpose is served; erasure requests cannot be honoured.
Root Cause	Retention and deletion were never designed into the data model.

Evidence (source trace)	`1. db/schema.sql:2  (no retention or deletion fields)`
	`CREATE TABLE employees (id SERIAL PRIMARY KEY, org_id INT, name TEXT, email TEXT, phone TEXT, department TEXT, date_of_birth DATE, aadhaar_number VARCHAR(12), pan VARCHAR(10));`
	`2. db/schema.sql:3  (no retention or deletion fields)`
	`CREATE TABLE payslips (id SERIAL PRIMARY KEY, employee_id INT, month TEXT, net_pay NUMERIC, bank_account_no TEXT, ifsc TEXT, pan VARCHAR(10), pdf BYTEA);`

Recommendation	Add a retention policy per data type (respecting labour, tax and PF record-keeping laws) and a scheduled erasure job; add an erasure-request flow for Data Principals. Files to change: db/schema.sql, src/jobs/retention.js (new)
Production risk of the fix	Medium. Agree retention periods with HR and legal first; statutory payroll records may need longer retention than other data.
Regression test	Seed an employee marked exited beyond the retention period, run the job, assert the profile is anonymised and payslip PDFs are deleted.
Classification	CWE-212 | Confidence: High | Votes: 3 confirmed / 0 verify / 0 reject

F-03 Full 12-digit Aadhaar number is stored for every employee [MEDIUM]

Location	db/schema.sql:2
DPDP obligation	Purpose limitation and minimisation; Section 4, Section 6(1); Data: Aadhaar number
In plain words	What this is: The employees table has a column for the full Aadhaar number. Problem: No code reads it for any purpose, yet the full number is kept. If we skip it: The most sensitive identifier is held without need, raising the impact of any breach.
Description	employees.aadhaar_number holds the full 12-digit value. No route, job or query in src/ reads the column (grep for aadhaar in src/ returns no read path), so storage serves no implemented purpose.

Business Impact	Unnecessary holding of Aadhaar numbers increases breach impact and conflicts with purpose limitation.
Root Cause	Fields added to the schema without a defined purpose.
Evidence (source trace)	`1. db/schema.sql:2  (full Aadhaar column)` `CREATE TABLE employees (id SERIAL PRIMARY KEY, org_id INT, name TEXT, email TEXT, phone TEXT, department TEXT, date_of_birth DATE, aadhaar_number VARCHAR(12), pan VARCHAR(10));`
Recommendation	Drop the column or replace it with a token from an Aadhaar Data Vault or KYC provider reference; if a process outside this repo needs it, document the purpose and encrypt it. Files to change: db/schema.sql
Production risk of the fix	Low in this repo (no readers). Confirm no external report or integration reads the column before dropping it.
Regression test	Schema test asserts no column named aadhaar_number exists or that it holds only tokens.
Classification	CWE-359 | Confidence: High | Votes: 2 confirmed / 1 verify / 0 reject (dissent: One verifier noted an external KYC process might use the column outside this repository.)

4. Findings Requiring Manual Verification

The items below are specific, source-grounded concerns that depend on one fact the repository does not show (for example a cloud, hosting, identity-provider or production setting). They are listed separately and must not be treated as confirmed vulnerabilities until verified.

V-01 No notice is visible where employee personal data is collected [UNVERIFIED]

Location	db/schema.sql:2 (no collection UI in this repository)
Description	The repository stores employee contact, date of birth, Aadhaar and PAN, but contains no onboarding form or notice text. Collection may happen in another system (HRMS onboarding, paper forms) that is not in scope.
Missing fact	Where and how employee data is collected, and whether a notice under Section 5 is given at that point (or the processing relies on the employment legitimate use under Section 7).
Why it needs verification	The collection flow is not part of this repository.
Potential impact if confirmed	If no notice is given and consent is the basis, processing lacks a valid basis for each data type.
Safe check to settle it	Ask HR or the onboarding system owner for the collection screen or form and the notice text shown; confirm it lists the data, the purposes and how to exercise rights.

Evidence (source trace)	`1. db/schema.sql:2  (personal data stored)` `CREATE TABLE employees (id SERIAL PRIMARY KEY, org_id INT, name TEXT, email TEXT, phone TEXT, department TEXT, date_of_birth DATE, aadhaar_number VARCHAR(12), pan VARCHAR(10));`

5. Coverage & What Was Not Checked

- Coverage units: 0 total (none)
- Scanner leads raised: 0 (traced by hunters: 0, dismissed with a reason: 0, dependency items: 0)
- Candidates verified: 4 (3 confirmed, 1 need verification, 0 rejected as false positives)

Not checked

- trivy (dependency CVEs, IaC/Dockerfile misconfiguration, secrets) did not run: not_installed
- Runtime behaviour, live infrastructure, cloud console and hosting dashboard settings (source-only audit; see items requiring verification)

Not verifiable from source code

These obligations depend on documents, contracts or operations outside the code. They were neither marked as gaps nor as met:

- Published privacy notice and its language versions outside the application
- Contracts with Data Processors, including Rule 6 security clauses
- Appointment and contact of a DPO or grievance officer (where not shown in the app)
- Breach intimation procedure to the Data Protection Board and Data Principals (Rule 7)
- Actual production retention, backups and log retention where not defined in code or IaC
- Significant Data Fiduciary duties: DPIA, independent audit, algorithmic due diligence (if notified)
- What third-party recipients do with the data they receive

6. DPDP Obligation Mapping

Obligation	Act / Rules reference	Confirmed	Verify	Status
Notice	Rule 3, Section 5, Section 7	-	V-01	UNVERIFIED
Purpose limitation and minimisation	Section 4, Section 6(1)	F-03	-	GAP
Reasonable security safeguards	Rule 6(1)(a), Rule 6(1)(b), Section 8(5)	F-01	-	GAP
Retention and erasure	Rule 8, Section 12(3), Section 8(7)	F-02	-	GAP

7. Priority Remediation Order

Order reflects severity and how findings enable each other. Items requiring verification are placed where they would rank if confirmed.

#	Finding	Severity	Action
1	F-01	HIGH	Encrypt pan and bank_account_no at rest (pgcrypto or application-level envelope encryption with a KMS key) and return masked values from the API.
2	F-02	HIGH	Add a retention policy per data type (respecting labour, tax and PF record-keeping laws) and a scheduled erasure job;
3	V-01	UNVERIFIED	Ask HR or the onboarding system owner for the collection screen or form and the notice text shown;
4	F-03	MEDIUM	Drop the column or replace it with a token from an Aadhaar Data Vault or KYC provider reference;

8. Disclosure

This report was prepared from an authorized, read-only review of the application's source code. No target code was executed and no live system, API, database or cloud account was contacted. No exploit code, live credential values or step-by-step exploitation sequences are included, in line with responsible disclosure practice. This document is confidential and intended solely for the teams responsible for remediation.

This is an engineering review of source code against the DPDP Act 2023 and DPDP Rules 2025. It is not legal advice and does not certify compliance. Confirm interpretations with qualified legal counsel.

Findings reflect the source at the commit stated in the scope section. A clean result means no issue passed the evidence gate in the checked scope; it is not a guarantee that no vulnerability exists.

Generated with AI-Security-Audit-Skills v1.0.0 (https://github.com/risewithvj/AI-Security-Audit-Skills), created by Vijaya Kumar L (Rise With VJ).

Report Date: November 10, 2026